

LEMBAR KERJA PRAKTIKUM (LKP-PTM-06) TERISI LENGKAP

Implementasi Backend API, Autentikasi JWT, & Keamanan OWASP API

LEMBAR KERJA PRAKTIKUM / LAPORAN TUGAS	IDENTITAS MAHASISWA / PEMBUAT
Dokumen: LKP-PTM-06 (Backend & OWASP Security) Topik: Pertemuan 06 dari 16 Mata Kuliah: Intelligent Mobile & Web Application Development Dosen Pengampu: Edwin Hari Agus Prastyo, S.Kom., M.Kom.	Nama Mahasiswa: ALDI TUNGGAL JAYA NIM: 2395114002 Program Studi: Teknik Informatika (S1) Semester / T.A.: Ganjil 2025/2026 Status: Submisi Terisi Lengkap

E. LEMBAR KERJA ISIAN MAHASISWA

E.1 Daftar Endpoint Backend & Status Implementasi Lapisan

Berikut adalah daftar seluruh endpoint backend yang diimplementasikan berdasarkan spesifikasi OpenAPI 3.0 (PTM-05) menggunakan arsitektur modular 3 lapisan (**Router** → **Service** → **Repository**):

No	Endpoint	HTTP	Lapisan Terpasang	Status & OWASP Check
1	/auth/signup	POST	auth_router → auth_service → user_repo	Lolos (Bcrypt Hash + Unique Email)
2	/auth/login	POST	auth_router → auth_service → user_repo	Lolos (OAuth2 Password + JWT Pair)
3	/auth/refresh	POST	auth_router → auth_service → token_repo	Lolos (DB Token Revocation Check)
4	/auth/me	GET	auth_router → auth_service → user_repo	Lolos (Protected Route Bearer JWT)
5	/diseases	GET	disease_router → disease_service → disease_repo	Lolos (Public Read-Only Catalog)
6	/diseases/{disease_id}	GET	disease_router → disease_service → disease_repo	Lolos (UUID v4 Validation)
7	/predictions [*AI]	POST	prediction_router → prediction_service → prediction_repo	Lolos (Sanitasi File 5 Layer + User Binding)
8	/predictions [*AI]	GET	prediction_router → prediction_service → prediction_repo	Lolos Anti-BOLA (WHERE user_id = current_user)
9	/predictions/{id} [*AI]	GET	prediction_router → prediction_service → prediction_repo	Lolos Anti-BOLA (user_id == current_user)

Mekanisme Sanitasi Masukan AI 5 Layer (OWASP API4:2023):

- Size Guard:** Membatasi ukuran berkas maksimal 10MB (HTTP 413 Payload Too Large).
- MIME Whitelisting:** Mengunci tipe media hanya untuk image/jpeg dan image/png.
- Magic Bytes Check:** Verifikasi biner header file (FF D8 FF / 89 50 4E 47) anti-extension spoofing.
- Filename Randomization:** Mengubah nama berkas menjadi UUID v4 acak mencegah Path Traversal.
- PIL Re-encoding & Fallback Threshold:** Membaca ulang piksel untuk mengikis malware EXIF. Jika confidence score < 0.70, sistem memicu fallback warning ([BR-01, AC-02]).

E.2 Iterasi & Revisi Prompt AI

Prompt	Masalah Output Pertama	Revisi / Prompt Lanjutan Digunakan
D.1 Scaffold Modular	Router menaruh kueri SQLAlchemy langsung tanpa Repository layer.	Refaktor arsitektur menjadi 3 layer terpisah: Router (HTTP), Service (Biz Logic), Repository (DB Query).
D.2 Autentikasi JWT	Pydantic ImportError akibat dependensi email-validator tidak terpasang.	Ganti EmailStr dengan str terannotasi Field(pattern=r'^[a-zA-Z0-9_+]+@[a-zA-Z0-9-]+\.[a-zA-Z0-9-]+\$',).
D.3 Audit OWASP & BOLA	GET /predictions/{id} mengembalikan diagnosa tanpa verifikasi user_id.	Tambahkan filter kepemilikan: WHERE predictions.id = :id AND user_id = :current_user.id. Lempar 404 jika tidak cocok.

E.3 Asumsi Teknis & Keputusan Desain Backend [ASUMSI-XX]

Kode	Isi Asumsi / Keputusan Desain AI	Verifikasi (Diterapkan / Diubah)
[ASUMSI-07]	Arsitektur FastAPI menggunakan pola modular Router-Service-Repository.	Diterapkan. Memisahkan kueri basis data dan logika bisnis dari HTTP handler.
[ASUMSI-08]	Token Refresh disimpan di DB (refresh_tokens) untuk instant session revocation.	Diterapkan. Meningkatkan keamanan dari kebocoran token jangka panjang.
[ASUMSI-09]	Kegagalan otorisasi BOLA direspons HTTP 404 Not Found alih-alih 403 Forbidden.	Diterapkan. Mencegah resource enumeration attack (OWASP API3:2023).
[ASUMSI-10]	Model AI diakomodasi via mock inference engine TF-Lite/ONNX 5 kelas.	Diterapkan. Menjamin fungsionalitas inferensi backend tervalidasi 100%.

F. LOG PROMPT WAJIB (ptm-06-prompt-log)

No	Target Prompt	Alat AI & Versi	Ringkasan Prompt	Skor	Revisi Manual
1	D.1 Scaffold Modular	Gemini Notebook	Generate folder modular Router-Service-Repo & env.example.	4/5	Pisahkan config.py dan database.py ke app/core/.
2	D.2 Autentikasi JWT	Gemini Notebook	Alur signup, login bcrypt, token pair (access 30m / refresh 7d), & /auth/me.	5/5	Penyesuaian regex email Pydantic v2 tanpa plugin.
3	D.3 Audit OWASP & BOLA	Gemini Notebook	Audit OWASP Top 10, patch BOLA pada /predictions/{id}, & sanitasi upload.	5/5	Tambah validasi magic bytes biner pada upload.
4	Iterasi Postman Export	Gemini Notebook	Spesifikasi Postman Collection v2.1.0 dengan skrip uji otomatis.	5/5	Tambah variabel pm.environment.set pada Postman.

G. DELIVERABLE ARTEFAK REPOSITORI

File / Artefak	Lokasi Repositori	Keterangan Status
Source Code Backend	backend/app/ (routers, services, repos, core)	Selesai (Python 3.12, FastAPI, SQLAlchemy 2.0, Pydantic v2)
.env.example	Root direktori repositori	Selesai (Template variabel lingkungan tanpa hardcoded secrets)
postman-collection.json	docs/postman/postman-collection.json	Selesai (Koleksi Postman v2.1.0 Happy/Error Path & BOLA test)
owasp-audit.md	docs/security/owasp-audit.md	Selesai (Laporan audit OWASP API Top 10 2023 & patch Anti-BOLA)
ptm-06-prompt-log.md	docs/prompt-log/ptm-06-prompt-log.md	Selesai (Log prompt, iterasi AI, evaluasi, & asumsi teknis)
LKP-PTM-06 Terisi	docs/lkp/LKP-PTM-06-IMWAD-TERISI.pdf	Terisi Lengkap oleh Aldi Tunggal Jaya (2395114002)

Deklarasi Integritas Akademik & Tanda Tangan:

'Saya memahami seluruh isi tugas ini, mengerjakan secara mandiri sesuai panduan, dan menggunakan AI sebagai alat bantu yang dideklarasikan secara jujur.'

Nama Mahasiswa & NIM	Tanda Tangan	Tanggal Submisi
ALDI TUNGGAL JAYA NIM: 2395114002	Aldi Tunggal Jaya (Digital Signed)	09 Oktober 2026